LESSON 6.1.1

Establish AI Governance

How organizations build the people, policies, processes, and technical controls to keep AI lawful, secure, and aligned with business goals.

What Is AI Governance?

A management system that decides:

- → Whether to use AI
- → How to design, build & deploy it
- → What controls apply at every stage
- → How to monitor it over time

👥 People	📋 Policy
⚙️ Process	🔒 Technical Guardrails

Together, these ensure AI remains **lawful, secure, reliable,** and aligned with business objectives.

AI Center of Excellence (CoE)

A **cross-functional team** serving as the organization's hub for safe and effective AI implementation.

Who's Involved

AI engineering, data science, security, privacy, legal, compliance, risk, procurement, IT ops, product

What They Do

Define standards, review projects, curate tools, advise on risk, write policy, lead AI incident investigations

Why It Matters

Single accountable body ensuring all AI initiatives are safe, compliant, and aligned with business goals

Three CoE Operating Models

1

Centralized

All AI development and governance in one team. Maximum control, less agility.

2

Federated

Developers sit in business units. CoE acts as standards and assurance function.

3

Hybrid ⭐

Centralized platforms, policies & reviews. Business units develop within predefined boundaries.

The **hybrid model** is most common — it balances control with operational efficiency.

AI Policy: What It Covers

States what is **allowed**, what **evidence** is required, and who is **authorized** to decide. Short enough to read in one sitting.

- Purpose & Scope
- Roles & Accountability
- Data Use
- Model Lifecycle
- Human Oversight
- Security & Privacy
- Incident Response

When Formal Sign-Off Is Required

🚀 Moving to Production

Model promoted from testing into live environment

🗄️ Customer Data for Training

Using personal or customer data to train or fine-tune models

🤖 Autonomous Actions

Enabling automated emails, transactions, or decisions without human review

Plain Language Matters

Definitions must be unambiguous. Example:

> "**High-risk AI**" — systems that influence **credit, employment, health, safety,** or **core security** functions.

Clear definitions support both enforcement and audits.

AI Procedures: Policy in Action

Procedures convert policy into **predictable, auditable steps** specifying who does what, when, and with what evidence.

1. **Risk Classification**
   Categorize the AI use case by risk level before work begins
2. **Design Review**
   CoE reviews architecture, data sources, and fairness considerations
3. **Testing & Validation**
   Evidence-based testing for accuracy, bias, and security
4. **Release & Change Control**
   Formal sign-off before deployment or model updates
5. **Monitoring & Response**
   Ongoing tracking; incident response when issues arise

Well-written procedures are **plain-language and role-based** enabling speed without sacrificing control.

Technical Guardrails

Controls that **enforce governance** in day-to-day AI operations creating boundaries and continuous visibility.

Model & Prompt Registries

Versioning for all models and prompts

Access Controls

Least-privilege principles; secrets management

Data Masking & Quality

Protect sensitive data; validate inputs

Logging & Audit Trails

Full traceability of decisions and actions

Prompt & Response Filtering

Block unsafe patterns at input and output

AI GRC Maturity Roadmap

Governance, Risk & Compliance programs mature through three stages from foundational policy to automated, independently validated controls.

Stage 1 — Foundation

Publish a concise AI policy. Inventory all existing AI uses across the organization.

Stage 2 — Build

Establish a model registry. Adopt an industry standard framework. Build monitoring capabilities.

Stage 3 — Optimize

Refine risk practices. Automate evidence collection. Seek 3rd-party validation for high-risk systems.

Key Takeaways

1

Governance = People + Policy + Process + Technology

Effective AI governance combines all four layers — no single element is sufficient alone.

2

The CoE Is Your Governance Hub

A cross-functional AI CoE defines standards, reviews projects, and owns policy. Hybrid models offer the best balance.

3

Policy Must Be Clear & Enforceable

Short, plain-language policies with defined roles and unambiguous definitions (e.g., "high-risk AI") enable real enforcement.

4

Procedures Create Auditability

Role-based procedures across the AI lifecycle ensure traceable, consistent decisions at every stage.

5

Technical Guardrails Enforce Controls Daily

Registries, access controls, audit logs, and filtering translate governance policy into operational reality.

6

Mature GRC in Stages

Start with a policy and inventory, then build registries and monitoring, then automate and seek independent validation.